Documento de Matriz de Controle de Acesso (RBAC)

1. Nomenclatura dos Perfis (Roles)

Para facilitar a leitura técnica, os perfis identificados no sistema recebem as seguintes nomenclaturas em código:

- **ANON:** Público / Visitante (Usuário não autenticado).
- **CONDUTOR:** PcD Condutor (Requerente).
- **NAO_CONDUTOR:** PcD Não Condutor (Requerente).
- **ADMIN:** Administrador do Sistema (SysAdmin).
- **SUPORTE:** Equipe de Atendimento / Suporte Técnico.
- **AUTH:** Qualquer usuário logado (A soma de CONDUTOR, NAO_CONDUTOR, ADMIN e SUPORTE).

2. Matriz de Acesso: Telas e Navegação (Frontend)

O Frontend deve utilizar Route Guards (proteção de rotas no React/Router) para bloquear o acesso às URLs abaixo com base no papel do usuário.

Área Pública (Não Logada)

- **/login** (Tela de Autenticação)
  - **Perfis com acesso:** ANON
- **/cadastro** (W01 - Tela de Onboarding)
  - **Perfis com acesso:** ANON
- **/esqueci-senha e /resetar-senha** (Recuperação)
  - **Perfis com acesso:** ANON

Área do Requerente (Processo de Isenção)

- **/dashboard** (W05 - Resumo / Visão Geral e Roadmap)
  - **Perfis com acesso:** CONDUTOR, NAO_CONDUTOR
- **/documentos/upload** (W02 - Envio de Laudos e CNH)
  - **Perfis com acesso:** CONDUTOR, NAO_CONDUTOR
- **/documentos/checklist** (W03 - Painel de Pendências)
  - **Perfis com acesso:** CONDUTOR, NAO_CONDUTOR
- **/processo/*** (W04 e W06 - Abas Multiórgãos e Stepper)
  - **Perfis com acesso:** CONDUTOR, NAO_CONDUTOR
- **/condutores** (W07 - Gestão de Condutores Autorizados)
  - **Perfis com acesso:** Somente NAO_CONDUTOR (Acesso estritamente bloqueado para o perfil CONDUTOR).
- **/revisao-final** (W08 - Tela de Revisão e Conclusão)
  - **Perfis com acesso:** CONDUTOR, NAO_CONDUTOR

Área de Gestão e Backoffice

- **/admin/metricas** (Dashboard de Estatísticas de Uso)
  - **Perfis com acesso:** Somente ADMIN
- **/admin/configuracoes** (Parametrização de Regras)
  - **Perfis com acesso:** Somente ADMIN

- **/suporte/consultas** (Busca de processos e status)
  - **Perfis com acesso:** ADMIN, SUPORTE (Nota: Visualização de arquivos médicos ocultada na interface para o perfil SUPORTE).

3. Matriz de Acesso: Rotas da API (Backend)

O Backend deve aplicar as anotações de autorização (ex: [Authorize(Roles = "...")] no ASP.NET Core) exatamente conforme o mapeamento abaixo. Nenhuma rota, exceto as públicas, deve ficar sem a Fallback Policy de autenticação.

Módulo de Autenticação e Conta (/api/auth e /api/users)

- **POST /api/auth/register** (Criar conta)
  - **Acesso:** ANON
- **POST /api/auth/login** (Gerar JWT)
  - **Acesso:** ANON
- **POST /api/auth/forgot-password** (Solicitar código)
  - **Acesso:** ANON
- **POST /api/auth/reset-password** (Redefinir com código)
  - **Acesso:** ANON
- **GET /api/auth/me** (Dados do usuário logado)
  - **Acesso:** AUTH (Todos os perfis autenticados)
- **PATCH /api/auth/change-password** (Trocar senha logado)
  - **Acesso:** AUTH (Todos os perfis autenticados)
- **POST /api/auth/logout** (Revogar Token / JTI)
  - **Acesso:** AUTH (Todos os perfis autenticados)
- **DELETE /api/users/{userId}** (Anonimizar conta e apagar arquivos LGPD)
  - **Acesso:** Policy SelfOrAdmin (O próprio dono da conta através do ID **OU** o perfil ADMIN).

Módulo de Processos e Documentos (/api/processos e /api/documentos)

- **GET /api/processos/me** (Buscar rascunho/progresso atual)
  - **Acesso:** CONDUTOR, NAO_CONDUTOR
- **PUT /api/processos/me/etapas** (Auto-save de rascunho da etapa)
  - **Acesso:** CONDUTOR, NAO_CONDUTOR
- **POST /api/documentos/upload** (Receber anexo no Storage)
  - **Acesso:** CONDUTOR, NAO_CONDUTOR
- **GET /api/documentos/checklist** (Status dos arquivos)
  - **Acesso:** CONDUTOR, NAO_CONDUTOR
- **POST /api/processos/dossie/gerar** (Compilar PDF final)
  - **Acesso:** CONDUTOR, NAO_CONDUTOR

Módulo de Indicação de Condutores (/api/condutores)

- **GET /api/condutores** (Listar indicados do processo)
  - **Acesso:** Somente NAO_CONDUTOR
- **POST /api/condutores** (Adicionar novo - Sujeito a RN01 de Máx 3)
  - **Acesso:** Somente NAO_CONDUTOR
- **DELETE /api/condutores/{id}** (Remover um indicado)

- **Acesso:** Somente NAO_CONDUTOR

Módulo de Backoffice e Suporte (/api/admin e /api/suporte)

- **GET /api/admin/metricas** (Dados anonimizados de abandono/sucesso)
  - **Acesso:** Somente ADMIN
- **PUT /api/admin/parametros** (Alterar tempo de validade aceito de laudos)
  - **Acesso:** Somente ADMIN
- **GET /api/suporte/usuarios** (Consultar status da jornada do usuário por e-mail/CPF)
  - **Acesso:** ADMIN, SUPORTE (Dados médicos não trafegam no DTO de resposta desta rota para evitar vazamento via rede).

Legenda de Perfis:

- **ANON:** Público / Visitante (Não autenticado)
- **CONDUTOR:** PcD Condutor (Requerente)
- **NAO_CONDUTOR:** PcD Não Condutor (Requerente)
- **ADMIN:** Administrador do Sistema
- **SUPORTE:** Equipe de Atendimento Técnico
- **AUTH:** Todos os usuários autenticados
- **SelfOrAdmin:** O próprio dono da conta ou um Administrador

Camada	Rota / Tela	Método	Descrição do Recurso	Perfis Autorizados
Frontend	`/login`	-	Tela de Autenticação	**ANON**
Frontend	`/cadastro`	-	W01 - Tela de Onboarding	**ANON**
Frontend	`/esqueci-senha` e `/resetar-senha`	-	Recuperação de Senha	**ANON**
Frontend	`/dashboard`	-	W05 - Resumo / Visão Geral e Roadmap	**CONDUTOR, NAO_CONDUTOR**
Frontend	`/documentos/upload`	-	W02 - Envio de Laudos e CNH	**CONDUTOR, NAO_CONDUTOR**
Frontend	`/documentos/checklist`	-	W03 - Painel de Pendências	**CONDUTOR, NAO_CONDUTOR**
Frontend	`/processo/*`	-	W04 e W06 - Abas Multiórgãos e Stepper	**CONDUTOR, NAO_CONDUTOR**
Frontend	`/condutores`	-	W07 - Gestão de Condutores Autorizados	**NAO_CONDUTOR** *(Estrito)*
Frontend	`/revisao-final`	-	W08 - Tela de Revisão e Conclusão	**CONDUTOR, NAO_CONDUTOR**
Frontend	`/admin/metricas`	-	Dashboard de Estatísticas de Uso	**ADMIN**
Frontend	`/admin/configuracoes`	-	Parametrização de Regras	**ADMIN**
Frontend	`/suporte/consultas`	-	Busca de processos e status	**ADMIN, SUPORTE**
Backend	`/api/auth/register`	`POST`	Criar conta	**ANON**
Backend	`/api/auth/login`	`POST`	Gerar token JWT	**ANON**

Camada	Rota / Tela	Método	Descrição do Recurso	Perfis Autorizados
Backend	`/api/auth/forgot-password`	`POST`	Solicitar código de recuperação	**ANON**
Backend	`/api/auth/reset-password`	`POST`	Redefinir com código	**ANON**
Backend	`/api/auth/me`	`GET`	Dados do usuário logado	**AUTH**
Backend	`/api/auth/change-password`	`PATCH`	Trocar senha logado	**AUTH**
Backend	`/api/auth/logout`	`POST`	Revogar Token / JTI	**AUTH**
Backend	`/api/users/{userId}`	`DELETE`	Anonimizar conta e apagar arquivos	**SelfOrAdmin**
Backend	`/api/processos/me`	`GET`	Buscar rascunho/progresso atual	**CONDUTOR, NAO_CONDUTOR**
Backend	`/api/processos/me/etapas`	`PUT`	Auto-save de rascunho da etapa	**CONDUTOR, NAO_CONDUTOR**
Backend	`/api/documentos/upload`	`POST`	Receber anexo no Storage	**CONDUTOR, NAO_CONDUTOR**
Backend	`/api/documentos/checklist`	`GET`	Status dos arquivos anexados	**CONDUTOR, NAO_CONDUTOR**
Backend	`/api/processos/dossie/gerar`	`POST`	Compilar PDF final do processo	**CONDUTOR, NAO_CONDUTOR**
Backend	`/api/condutores`	`GET`	Listar indicados do processo	**NAO_CONDUTOR** *(Estrito)*
Backend	`/api/condutores`	`POST`	Adicionar novo condutor (Máx 3)	**NAO_CONDUTOR** *(Estrito)*
Backend	`/api/condutores/{id}`	`DELETE`	Remover um condutor indicado	**NAO_CONDUTOR** *(Estrito)*
Backend	`/api/admin/metricas`	`GET`	Dados anonimizados de sucesso/abandono	**ADMIN**
Backend	`/api/admin/parametros`	`PUT`	Alterar regras de tempo e validade	**ADMIN**
Backend	`/api/suporte/usuarios`	`GET`	Consultar status da jornada (sem dados sensíveis)	**ADMIN, SUPORTE**